

§7 — Records, Training & Incident Response

Study Sheet 03 · the proof, the people, the fire drill · Guardrail 9 + keep-alive

- Binding law (the floor) ■ Voluntary guidance ■ Frameworks & standards
- Controls (the toolbox) ■ Traps / red lines ■ Definitions

§7 is what keeps the whole policy alive and honest: you can prove it, people know it, and there's a plan when it breaks.

One-line frame: §1–§6 are the promises. §7 is the machinery that keeps them real — **Records** prove they were kept, **Training** puts them in people's heads, and **Incident Response** catches them when they fail.

Beat 1 · The Proof — Records (Guardrail 9)

● Definition

Records = a dated, attributable trail proving the policy was actually followed. The policy says what *should* happen; records prove what *did*.

policy makes promises → records = the evidence →

"prove it" → open the log, not your memory

● The trap (both ends)

- **Record nothing** → can't prove you followed your own policy (= treated like no governance at all).
- **Record everything** (every prompt/keystroke) → unusable noise + privacy liability (client data ends up in the logs).

● The rule

- Log **the decisions that matter**: tool approvals, AI disclosures, oversight sign-offs, incidents.
- Fields: **who / what / when**. Retention: **7 years** (AU financial-advice legal requirement). No needless client data in the log.

Beat 2 · The People — Training (keep-alive)

● Definition

Training = moving the rules off the page and into people's heads, where they change behaviour. A policy nobody knows is decoration.

policy written



staff actually trained



rules followed in practice

● The trap

- **"We emailed everyone the policy" = training**. Sending ≠ learning.
- One-time onboarding with no refresh, no new-staff coverage, no update when a new tool/rule lands → back to "policy in a folder."

● The rule

- **Train, don't just send** — before using AI, and again on every new tool/rule.
- **New starters** trained at onboarding · whole firm **refreshed at least annually**.
- The **director is accountable** for ensuring training happens (ties to §2).

Beat 3 · The Fire Drill — Incident Response

● Definition

Incident response = a pre-agreed plan for when AI causes (or nearly causes) harm or a breach, so nobody has to improvise mid-crisis.

CONTAIN

→

ASSESS

→

NOTIFY

→

FIX + LEARN

● The trap

- **"We'll deal with it if it happens"** = panic with extra steps.
- Treating **"turn the tool off"** as the whole response — it's only containment; it doesn't tell the clients who already got bad advice.

● The rule — the four steps

- **Contain** — director's kill switch, disable the tool (§2 authority used here).
- **Assess** — who/what is affected, how bad.
- **Notify** — affected clients + the **OAIC** where client data is breached (Privacy Act, mandatory).
- **Fix + Learn** — correct the harm, log it (Beat 1), change the process so it can't recur.
- Staff must report a suspected incident to the director **immediately** — "deal with it later" is not acceptable.

How §7 ties the policy together: Incident Response uses the director's kill-switch authority from **§2**; every incident is logged via **Records**; and Training is what keeps **§1–§6** alive in practice rather than rotting on a drive. §7 is the connective tissue of the whole policy.

AI Governance study library · Sheet 03 · maps to **ai-use-policy.md §7** (Hawthorn Wealth Managers) ·
Source: Voluntary AI Safety Standard, Guardrail 9 + keep-alive. **Policy now COMPLETE (§1–§7)**.
Status: covered — needs drilling.